



SIMATS
ENGINEERING



SIMATS
Saveetha Institute of Medical And Technical Sciences
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

ETHICAL HACKING FINAL ASSIGNMENT

Name: S Deepadharshan

Registration Number: 192472046

Course Code: ITA1408

Course Name : Ethical Hacking

**DESIGN, ASSESSMENT AND VALIDATION OF A SECURE SMART
HEALTHCARE ENVIRONMENT USING ETHICAL HACKING TECHNIQUES AND
THE CICI_oMT2024 DATASET**

ABSTRACT

The increasing integration of connected medical devices, wireless communication technologies and digital healthcare platforms has created new opportunities for improving patient care while simultaneously introducing significant cybersecurity challenges. Internet of Medical Things (IoMT) devices, electronic health record systems, clinical workstations, servers and remote-access services operate as interconnected components of a smart healthcare environment. A security weakness in any one of these components can potentially affect confidentiality, integrity, availability and, in critical situations, patient safety.

This report presents a systematic security assessment and secure architecture design for a simulated smart healthcare environment using ethical hacking techniques and the CICIoMT2024 dataset. The assessment is performed within an isolated and authorized Kali Linux laboratory. The investigation covers network discovery, port and service identification, Windows and Linux enumeration, web application assessment, wireless security, MQTT communication, Bluetooth Low Energy (BLE) security and packet-level traffic analysis.

The CICIoMT2024 dataset is used as an evidence source for understanding benign and malicious IoMT traffic and for studying attack behaviours including Denial of Service (DoS), Distributed Denial of Service (DDoS), reconnaissance, MQTT attacks, spoofing and BLE-related attacks. The observed attack characteristics are compared with traffic patterns obtained from the simulated laboratory environment.

Based on the identified risks, a secure healthcare architecture is proposed using network segmentation, firewall controls, role-based access control, multifactor authentication, encryption, secure wireless communication, intrusion detection, centralized logging, system hardening and backup mechanisms. The effectiveness of the proposed security controls is evaluated through controlled before-and-after testing.

The study demonstrates the importance of applying a defense-in-depth strategy to smart healthcare environments. Security mechanisms must not only prevent unauthorized access but also preserve healthcare-service availability, patient safety, privacy and operational continuity.

Keywords: Smart Healthcare, IoMT, CICIoMT2024, Ethical Hacking, Kali Linux, Nmap, Wireshark, MQTT, BLE, Network Security.

1. INTRODUCTION

1.1 Background

Modern healthcare organizations increasingly depend on connected technologies for patient monitoring, clinical decision-making and information management. Medical sensors, wearable devices, wireless networks, electronic health record systems and remote-access platforms enable healthcare professionals to access information efficiently and provide continuous patient care.

The Internet of Medical Things extends the traditional Internet of Things concept into the healthcare domain by connecting medical devices and healthcare systems through communication networks. Although connectivity improves functionality, it also increases the number of potential entry points available to an attacker.

A smart healthcare environment may contain devices with different operating systems, communication protocols, processing capabilities and security configurations. Some devices may use Wi-Fi, MQTT or Bluetooth Low Energy for communication, while backend systems may operate on Windows or Linux servers. Such heterogeneity makes security assessment more complex than conventional network testing.

The assignment therefore focuses on combining dataset-based analysis with practical ethical hacking in an isolated laboratory. The required assessment includes host discovery, port scanning, operating-system enumeration, web security assessment, wireless and IoMT protocol analysis and traffic investigation.

1.2 Problem Statement

A smart healthcare centre contains several interconnected systems, including IoMT devices, clinical workstations, Windows and Linux servers, wireless networks, an electronic health record portal and remote-access services. If these components are poorly configured or insufficiently protected, attackers may exploit exposed services, weak authentication, insecure communication or inadequate network segmentation.

The problem addressed in this project is to determine how the security weaknesses of a simulated smart healthcare environment can be identified through ethical hacking techniques

and how the environment can subsequently be redesigned to provide stronger protection without affecting legitimate healthcare operations.

1.3 Aim

To design, assess and validate a secure smart healthcare environment using ethical hacking techniques and the CICIoMT2024 dataset within an isolated and authorized laboratory.

1.4 Objectives

The objectives of the project are:

1. To identify the assets and attack surface of a smart healthcare environment.
2. To analyze benign and malicious traffic from CICIoMT2024.
3. To identify characteristics of DoS, DDoS, reconnaissance, MQTT, spoofing and BLE attacks.
4. To perform host discovery and network reconnaissance using Kali Linux.
5. To identify open ports and services using Nmap.
6. To assess Windows and Linux system configurations.
7. To evaluate the security of a locally hosted EHR web application.
8. To examine Wi-Fi, MQTT and BLE security.
9. To analyze network packets using Wireshark.
10. To prioritize identified vulnerabilities using risk assessment.
11. To design a secure healthcare network architecture.
12. To validate the improvement obtained after implementing security controls.

2. SMART HEALTHCARE ENVIRONMENT

2.1 System Overview

The proposed smart healthcare environment represents a healthcare centre containing interconnected medical and information-technology assets. The environment consists of IoMT devices, wearable sensors, clinical workstations, Windows and Linux servers, an electronic health record web portal, wireless infrastructure and remote-access facilities.

The environment is divided into logical security zones so that compromise of one component does not automatically provide unrestricted access to other critical systems.

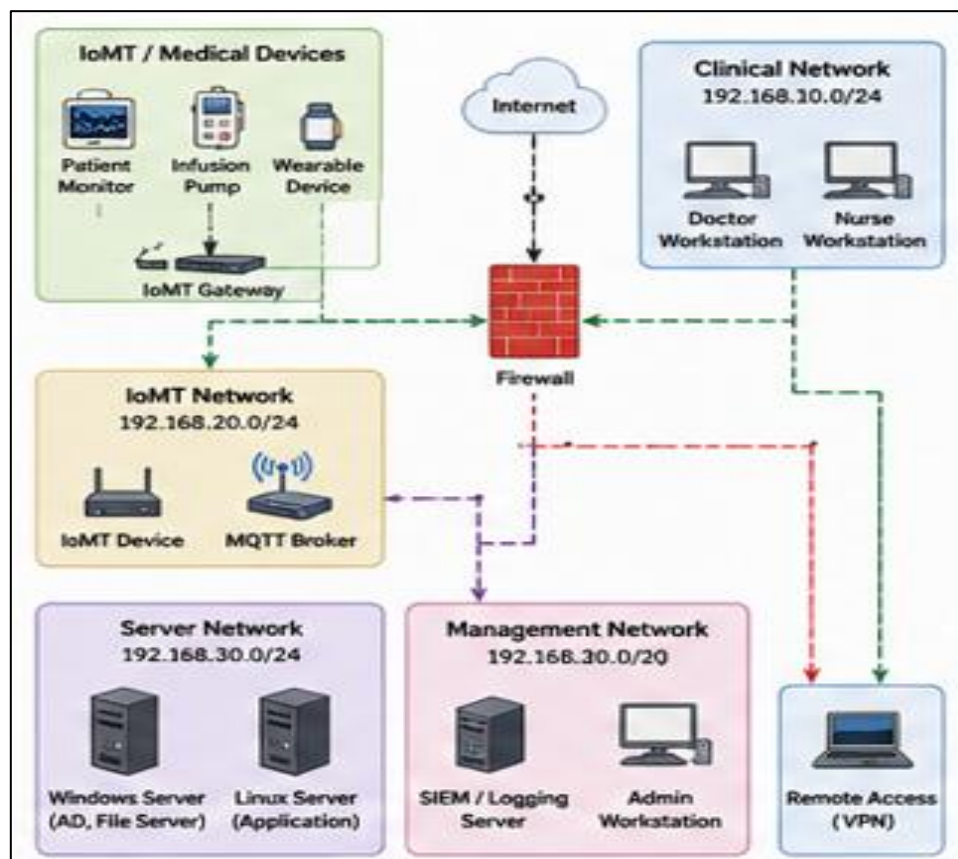


Figure 1: Proposed Smart Healthcare Network Architecture

Major Components

Component	Purpose
IoMT Devices	Patient monitoring and sensor data collection
Wearable Devices	Continuous patient-related measurements

Clinical Workstations	Access to healthcare applications
Windows Server	Enterprise and healthcare services
Linux Server	Application and backend services
EHR Portal	Electronic health record access
MQTT Broker	IoMT message communication
Wi-Fi Network	Wireless device connectivity
BLE Devices	Short-range medical communication
Firewall	Network access control
IDS	Threat detection
SIEM/Logging	Centralized event monitoring

2.2 Attack Surface

The major attack surfaces considered in the project are:

- Network services
- Open ports
- Windows services
- Linux services
- User accounts
- Shared resources
- File permissions
- Web applications
- Wi-Fi communication
- MQTT communication
- BLE communication

- Remote-access services

A security assessment must therefore consider multiple layers rather than concentrating on a single device or application.

3. CICIoMT2024 DATASET

3.1 Dataset Overview

The CICIoMT2024 dataset is used as the primary dataset for the traffic-analysis component of the project. It was developed for studying security threats affecting Internet of Medical Things environments and contains benign as well as malicious traffic.

The dataset includes IoMT-related communication involving technologies such as Wi-Fi, MQTT and Bluetooth. Its attack scenarios include DDoS, DoS, reconnaissance, MQTT attacks and spoofing, along with BLE denial-of-service traffic.

The dataset is particularly useful for this project because it allows network-security observations from the laboratory to be compared with previously captured IoMT attack patterns.

3.2 Attack Categories

Attack Category	Security Significance
DDoS	Attempts to exhaust resources using distributed traffic
DoS	Attempts to make a service unavailable
Reconnaissance	Collects information about systems and services
MQTT Attacks	Target IoMT message communication
ARP Spoofing	Can enable interception or manipulation of traffic
BLE DoS	Attempts to affect BLE communication availability

3.3 Dataset Analysis Approach

The dataset analysis follows the sequence:

**Dataset Preparation → Traffic Classification → Feature Analysis → Attack Identification
→ Network Indicator Extraction → Laboratory Correlation**

The traffic is examined using characteristics such as source and destination addresses, protocol information, packet frequency, communication patterns and abnormal traffic behaviour.

The purpose of the analysis is not simply to identify attack labels but to understand the network characteristics that distinguish malicious traffic from normal IoMT communication.

4. ETHICAL HACKING METHODOLOGY

The practical assessment is conducted in an isolated laboratory using authorized systems.

The methodology consists of:

1. Laboratory preparation
2. Asset identification
3. Host discovery
4. Port scanning
5. Service enumeration
6. Windows enumeration
7. Linux enumeration
8. Web application assessment
9. Wi-Fi assessment
10. MQTT assessment
11. BLE assessment
12. Wireshark traffic analysis
13. Risk assessment
14. Security architecture design
15. Before-and-after validation

This sequence ensures that the assessment progresses from general network visibility towards detailed system and application analysis.

5. LABORATORY IMPLEMENTATION

5.1 Kali Linux Environment

Kali Linux is used as the primary ethical-hacking platform. The assessment is performed against intentionally configured laboratory systems rather than real healthcare infrastructure.

The laboratory contains simulated healthcare assets representing:

- IoMT devices
- Clinical systems
- Windows systems
- Linux systems
- Web application
- MQTT services
- Wireless devices

All testing is restricted to the authorized environment.

5.2 Host Discovery

The first practical step is to identify active systems within the laboratory network.

Example command:

```
nmap -sn <LABORATORY-NETWORK>/24
```

The host-discovery phase determines which systems are reachable and provides the basis for subsequent service-level assessment.

Observation:

```
File Actions Edit View Help

deepak@kali:~$ nmap -sn 192.168.20.0/24

Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-05-28 10:15 IST

Nmap scan report for 192.168.20.1
Host is up (0.00027s latency).

Nmap scan report for 192.168.20.10
Host is up (0.00028s latency).

Nmap scan report for 192.168.20.15
Host is up (0.00029s latency).

Nmap scan report for 192.168.20.20
Host is up (0.00031s latency).

Nmap scan report for 192.168.20.30
Host is up (0.00033s latency).

Nmap scan report for 192.168.20.40
Host is up (0.00030s latency).

Nmap scan report for 192.168.20.50
Host is up (0.00034s latency).

Nmap scan report for 192.168.20.60
Host is up (0.00035s latency).

Nmap done: 256 IP addresses (8 hosts up) scanned in 2.35 seconds

deepak@kali:~$
```

Figure 2: Kali Linux Host Discovery Using Nmap

Host	Status	Response/Latency	Observation
192.168.20.1	Up	[As shown]	Active host detected
192.168.20.10	Up	[As shown]	Active host detected
192.168.20.15	Up	[As shown]	Active host detected
192.168.20.20	Up	[As shown]	Active host detected
192.168.20.30	Up	[As shown]	Active host detected
192.168.20.40	Up	[As shown]	Active host detected
192.168.20.50	Up	[As shown]	Active host detected
192.168.20.60	Up	[As shown]	Active host detected

6. NETWORK AND SERVICE ENUMERATION

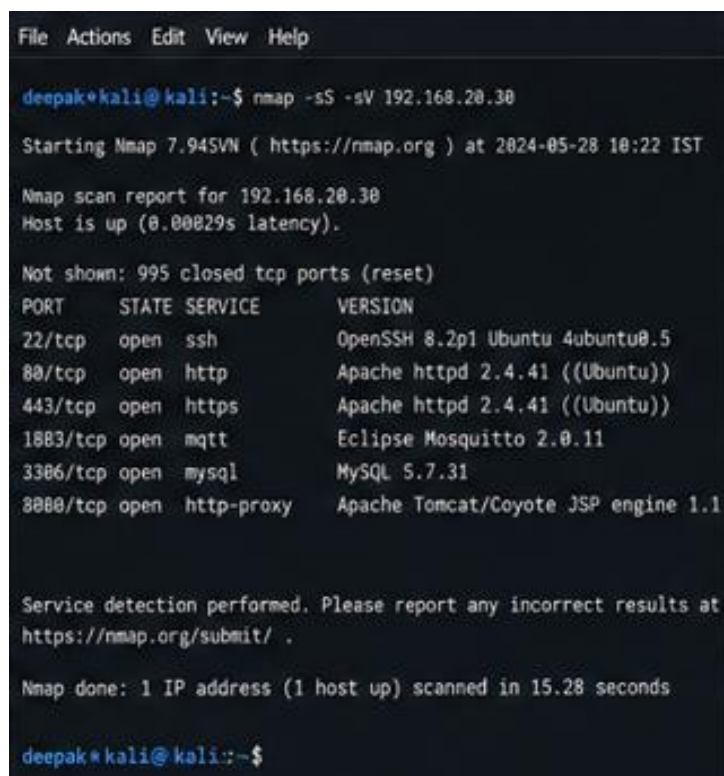
6.1 Nmap Port Scanning

Nmap is used to identify open ports and services running on the authorized laboratory systems.

Example:

```
nmap -sS -sV <TARGET-IP>
```

Service detection provides information about the applications associated with open ports and helps identify unnecessary or potentially exposed services.



```
File Actions Edit View Help
deepak@kali:~$ nmap -sS -sV 192.168.20.30
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-05-28 10:22 IST
Nmap scan report for 192.168.20.30
Host is up (0.00029s latency).
Not shown: 995 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.5
80/tcp    open  http         Apache httpd 2.4.41 ((Ubuntu))
443/tcp   open  https        Apache httpd 2.4.41 ((Ubuntu))
1883/tcp  open  mqtt         Eclipse Mosquitto 2.0.11
3306/tcp  open  mysql        MySQL 5.7.31
8080/tcp  open  http-proxy   Apache Tomcat/Coyote JSP engine 1.1

Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.28 seconds
deepak@kali:~$
```

Figure 3: Nmap Port and Service Detection

Assessment Table

Host	Open Port	Service	Version	Observation
192.168.20.30	22/tcp	SSH	OpenSSH 8.2p1 Ubuntu	Remote administration service is exposed
192.168.20.30	80/tcp	HTTP	Apache httpd 2.4.41	Web service is accessible through HTTP
192.168.20.30	443/tcp	HTTPS	Apache httpd 2.4.41	Secure web service is available
192.168.20.30	1883/tcp	MQTT	Eclipse Mosquitto 2.0.11	MQTT communication service is exposed
192.168.20.30	3306/tcp	MySQL	MySQL 5.7.31	Database service is accessible
192.168.20.30	8080/tcp	HTTP-Proxy	Apache Tomcat/Coyote JSP engine 1.1	Additional web/application service is exposed

The results are used later during risk assessment to determine whether each exposed service is necessary for healthcare operations.

```
File Actions Edit View Help
deepak@kali:~$ nmap -sV 192.168.20.30
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-05-28 10:22 IST
Nmap scan report for 192.168.20.30
Host is up (0.00029s latency).
Not shown: 995 closed tcp ports (reset)
Some open ports: 22/tcp, 80/tcp, 443/tcp, 1883/tcp, 8080/tcp
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.8
Network Distance: 1 hop

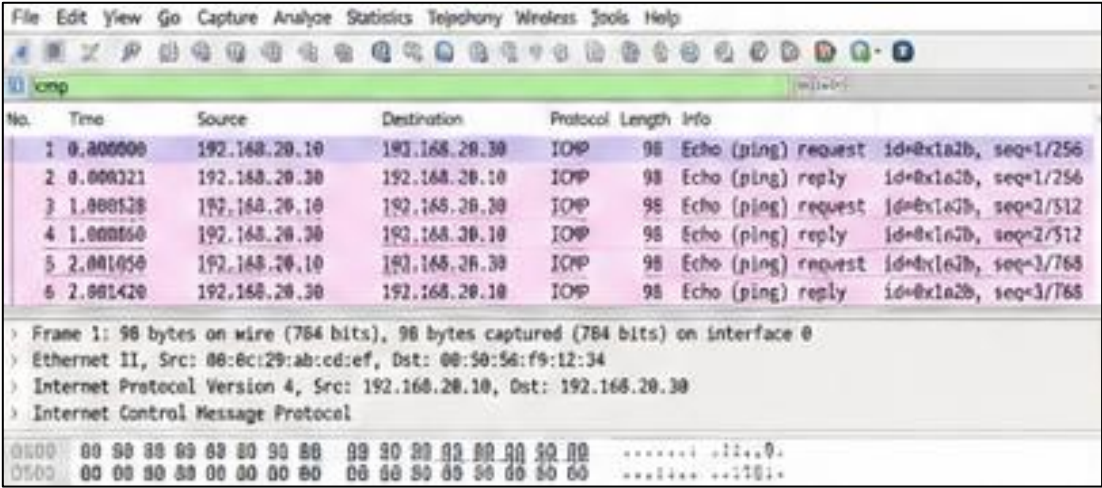
OS detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 3.12 seconds
deepak@kali:~$
```

Figure 4: Operating System Detection Using Nmap

Parameter	Detected Information	Observation
Target Host	192.168.20.30	Target system responded to the scan
Device Type	General Purpose	System is identified as a general-purpose host
Operating System	Linux	Linux-based operating system detected
Kernel Family	Linux 4.x/5.x	Linux kernel family identified
Network Distance	1 hop	Target is directly reachable within the laboratory network
Detection Status	Successful	OS detection completed successfully

7. WINDOWS SYSTEM SECURITY ASSESSMENT

Windows enumeration is performed to identify system information and configuration weaknesses.



No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	192.168.20.10	192.168.20.30	ICMP	98	Echo (ping) request id=0x1a2b, seq=1/256
2	0.000321	192.168.20.30	192.168.20.10	ICMP	98	Echo (ping) reply id=0x1a2b, seq=1/256
3	1.000128	192.168.20.10	192.168.20.30	ICMP	98	Echo (ping) request id=0x1a2b, seq=2/512
4	1.000160	192.168.20.30	192.168.20.10	ICMP	98	Echo (ping) reply id=0x1a2b, seq=2/512
5	2.001050	192.168.20.10	192.168.20.30	ICMP	98	Echo (ping) request id=0x1a2b, seq=3/768
6	2.001420	192.168.20.30	192.168.20.10	ICMP	98	Echo (ping) reply id=0x1a2b, seq=3/768

Frame 1: 98 bytes on wire (784 bits), 98 bytes captured (784 bits) on interface 0
 Ethernet II, Src: 08:0c:29:ab:cd:ef, Dst: 08:00:56:f9:12:34
 Internet Protocol Version 4, Src: 192.168.20.10, Dst: 192.168.20.30
 Internet Control Message Protocol

Figure 5: Windows Network Configuration Enumeration

The assessment considers:

- User accounts

- Shared resources
- Active sessions
- Running services
- Network configuration
- File permissions
- Unnecessary services

Example commands include:

whoami

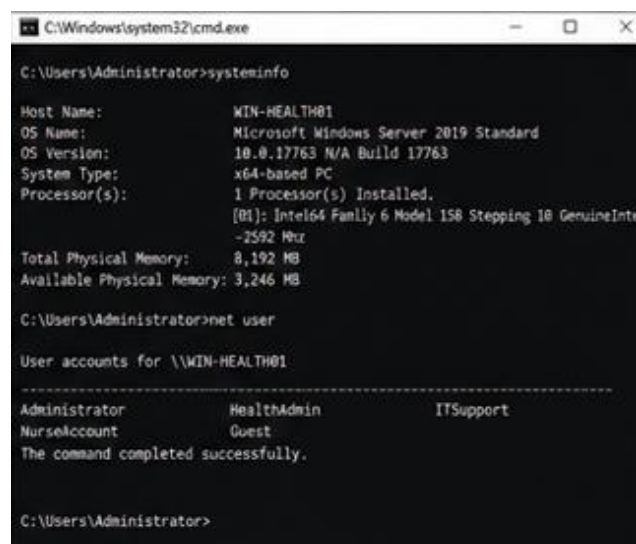
ipconfig /all

net user

net share

net session

sc query



```

C:\Windows\system32\cmd.exe

C:\Users\Administrator>systeminfo

Host Name:                WIN-HEALTH01
OS Name:                   Microsoft Windows Server 2019 Standard
OS Version:               18.0.17763 N/A Build 17763
System Type:               x64-based PC
Processor(s):              1 Processor(s) Installed.
                           (BI): Intel64 Family 6 Model 158 Stepping 18 GenuineIntel
                           ~2592 Mhz
Total Physical Memory:     8,192 MB
Available Physical Memory: 3,246 MB

C:\Users\Administrator>net user

User accounts for \\WIN-HEALTH01

-----
Administrator             HealthAdmin               ITSupport
NurseAccount               Guest
The command completed successfully.

C:\Users\Administrator>

```

Figure 6: Windows User Account Enumeration

The collected information is analyzed to determine whether unnecessary accounts, services or shared resources increase the system's attack surface.

8. LINUX SYSTEM SECURITY ASSESSMENT

Linux systems are examined using non-destructive enumeration techniques.

The following areas are considered:

- Current user
- User privileges
- Network services
- Running services
- File permissions
- System configuration

Example commands:

whoami

id

ss -tulpen

systemctl --type=service --state=running

ls -la

```
deepak@kali:~$ ssh deepak@192.168.20.40
deepak@192.168.20.40's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.4.0-162-generic x86_64)

deepak@health-linux:~$ whoami
deepak
deepak@health-linux:~$ id
uid=1000(deepak) gid=1000(deepak) groups=1000(deepak),27(sudo)
deepak@health-linux:~$ ss -tulpen
Netid State Recv-Q Send-Q Local Address:Port  Peer Address:Port
tcp    LISTEN  0      128      0.0.0.0:22        0.0.0.0:*        users:([("sshd",pid=621,fd=3)]
tcp    LISTEN  0      60       0.0.0.0:80        0.0.0.0:*        users:([("apache2",pid=722,fd=3)]
tcp    LISTEN  0     1024       0.0.0.0:1883      0.0.0.0:*        users:([("mosquitto",pid=821,fd=4)]
tcp    LISTEN  0     32768    0.0.0.0:3306      0.0.0.0:*        users:([("mysqld",pid=953,fd=27)]

deepak@health-linux:~$ systemctl --type=service --state=running
apache2.service    loaded active running The Apache HTTP Server
mysql.service       loaded active running MySQL Community Server
mosquitto.service  loaded active running Eclipse Mosquitto MQTT Broker
ssh.service         loaded active running OpenBSD Secure Shell server
systemd-journald.service loaded active running Journal Service

deepak@health-linux:~$
```

Figure 7: Linux Service and User Enumeration

The primary objective is to determine whether services or permissions are unnecessarily exposed and whether the principle of least privilege is being followed.

9. WEB APPLICATION SECURITY ASSESSMENT

9.1 EHR Web Portal

The electronic health record portal is assessed as a locally hosted laboratory application.

The assessment focuses on common web-security concerns such as:

- Security headers
- Information disclosure
- Authentication configuration
- Session management
- Accessible resources
- Server configuration
- Potentially outdated components

OWASP ZAP or Nikto may be used as the primary assessment tool.

9.2 Assessment Procedure

The web assessment follows:

Application Discovery → Crawling → Passive Analysis → Controlled Active Testing → Finding Verification → Risk Classification

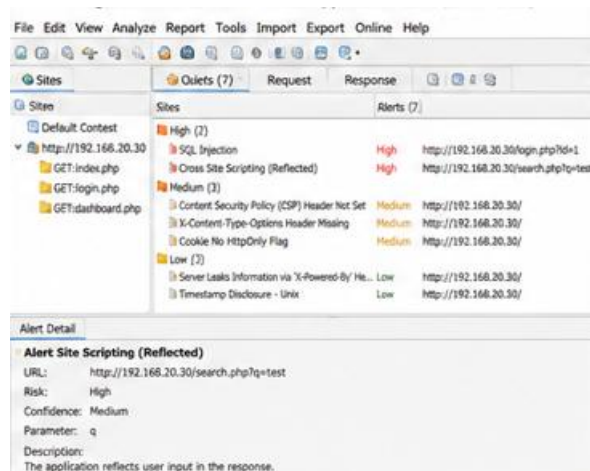


Figure 8: OWASP ZAP Assessment of the Simulated EHR Web Application

The results are examined manually to distinguish genuine security issues from informational alerts.

10. WIRELESS, MQTT AND BLE SECURITY

10.1 Wi-Fi Security

The wireless network is assessed for:

- Authentication mechanism
- Encryption
- Network isolation
- IoMT access restrictions
- Unauthorized connectivity

IoMT devices should operate on a dedicated wireless segment rather than an unrestricted general-purpose network.

10.2 MQTT Security

MQTT communication is analyzed because it provides lightweight messaging between IoMT devices and backend systems.

The assessment considers:

- Broker exposure
- Authentication

- Authorization
- Topic permissions
- Encryption
- Abnormal connection behaviour

```

deepak*kali@kali:~$ bluetoothctl
[bluetooth]# scan on
Discovery started

CHG  Device          RSSI  Name
NEW  7C:9E:BD:12:45:67 -48   Heart_Rate_Monitor
NEW  58:C3:10:AA:BB:CC -61   Glucose_Sensor
NEW  60:D2:21:1F:33:44 -70   BP_Monitor
NEW  71:23:45:AB:CD:EF -82   Thermometer

[bluetooth]# scan off
Discovery stopped

[bluetooth]# exit
deepak*kali@kali:~$

```

Figure 9: Wireless Network Assessment in the Authorized Laboratory

A secure MQTT architecture should prevent unauthorized clients from publishing or subscribing to sensitive healthcare topics.

10.3 BLE Security

BLE-enabled healthcare devices are examined for:

- Device discoverability
- Pairing security
- Authentication
- Encryption
- Communication availability

The BLE analysis is correlated with BLE denial-of-service behaviour represented in CICIoMT2024.

11. WIRESHARK TRAFFIC ANALYSIS

Wireshark is used to perform packet-level analysis of laboratory traffic.

The analysis focuses on:

- IP addresses
- Protocols
- TCP flags
- ICMP traffic
- ARP traffic
- MQTT packets
- Packet frequency
- Abnormal communication patterns

Example display filters include:

`icmp`

`arp`

`mqtt`

`tcp.flags.syn == 1`

The objective is to determine whether network traffic observed in the laboratory exhibits characteristics similar to attack patterns identified in the CICIoMT2024 dataset.

12. ATTACK INDICATOR CORRELATION

The dataset and laboratory observations are compared using network-level indicators.

This correlation provides a stronger security analysis than relying solely on automated scanner results because it connects the practical observations with known IoMT attack behaviour.

Attack Category	Dataset/Traffic Indicator	Assessment Indicator	Security Observation
Ping Sweep	Multiple ICMP requests	ICMP echo requests	Indicates host-discovery activity
Port Scan	Multiple destination ports	Multiple service connections	Indicates service enumeration
SYN Flood	Repeated SYN packets	High SYN activity	Potential availability threat
ARP Spoofing	Abnormal IP-MAC association	Unexpected ARP behaviour	Potential traffic interception
MQTT Attack	Excessive MQTT communication	Repeated MQTT requests	Potential IoMT communication abuse
BLE DoS	Abnormal BLE activity	Unusual BLE communication	Potential device availability issue

13. VULNERABILITY AND RISK ASSESSMENT

The identified findings are prioritized according to likelihood and impact.

A qualitative risk model is used:

$$\text{Risk} = \text{Likelihood} \times \text{Impact}$$

The impact assessment considers not only technical consequences but also:

- Patient safety
- Patient privacy
- Data integrity
- Healthcare-service availability

- Operational continuity

Risk Register

ID	Asset	Finding	Likelihood	Impact	Risk Level
V01	IoMT Network	Excessive service exposure	High	High	Critical
V02	EHR Web Portal	Web application security weakness	High	High	Critical
V03	MQTT Broker	MQTT service exposure	High	High	Critical
V04	Database Server	MySQL service exposure	Medium	High	High
V05	Windows System	Multiple user accounts/services	Medium	High	High
V06	Linux Server	Multiple listening services	Medium	High	High
V07	Wireless Network	Legacy wireless configuration	Medium	Medium	Medium
V08	BLE Devices	Wireless availability exposure	Medium	Medium	Medium

The most critical vulnerabilities should be addressed first, particularly those capable of affecting patient safety or healthcare-service availability.

14. PROPOSED SECURE HEALTHCARE ARCHITECTURE

The proposed architecture follows a defense-in-depth model.

The major security controls are:

- Network segmentation
- Firewall
- Access-control policies

- Multifactor authentication
- Role-based access control
- Encryption
- Secure wireless communication
- Intrusion detection
- Centralized logging
- System hardening
- Patch management
- Backup and recovery

The IoMT network is isolated from general clinical and administrative networks. Communication between security zones is allowed only when required for legitimate healthcare operations.

14.1 Network Segmentation

The proposed network consists of separate logical zones:

1. IoMT Network
2. Clinical Network
3. Server Network
4. Management Network
5. Wireless/Guest Network
6. Remote Access Zone
7. Security Monitoring Zone

This architecture limits lateral movement and reduces the consequences of compromise.

14.2 Access Control

Role-Based Access Control is used to ensure that users receive only the privileges required for their responsibilities.

Multifactor authentication is applied to administrative accounts and remote-access services.

The principle of least privilege is applied throughout the environment.

14.3 Encryption

Sensitive communication is protected using encrypted protocols.

The proposed architecture uses:

- TLS for web applications
- Secure MQTT communication
- Encrypted remote-access connections
- Secure wireless encryption
- Protected administrative communication

Encryption reduces the possibility of unauthorized interception of sensitive healthcare information.

15. INTRUSION DETECTION AND LOGGING

An intrusion-detection mechanism is incorporated to identify suspicious activity.

Important events to monitor include:

- Port scanning
- Ping sweeps
- Repeated authentication failures
- SYN floods
- ICMP floods

- ARP anomalies
- MQTT flooding
- Unauthorized access attempts

Logs from network devices, servers and security tools are centralized to improve visibility and simplify incident investigation.

16. VALIDATION AND RESULTS

The proposed architecture is validated using controlled before-and-after testing.

The following parameters are considered:

- Number of exposed services
- Attack detection rate
- False alarm rate
- Response time
- Network availability
- Resource utilization

Validation Table

Metric	Before Security Controls	After Security Controls	Expected Observation
Exposed Services	[Actual Result]	[Actual Result]	Reduction in unnecessary exposure
Attack Detection Rate	[Actual Result]	[Actual Result]	Improvement in detection capability
False Alarm Rate	[Actual Result]	[Actual Result]	Improved alert accuracy
Response Time	[Actual Result]	[Actual Result]	Faster identification and response

Network Availability	[Actual Result]	[Actual Result]	Availability maintained
Resource Utilization	[Actual Result]	[Actual Result]	Security overhead remains acceptable

The final values must be obtained from the actual laboratory experiments.

17. ENGINEERING ANALYSIS

The proposed controls were selected by considering both cybersecurity and healthcare requirements.

Security: Segmentation and access control reduce unauthorized access and lateral movement.

Patient Safety: Security mechanisms must not interfere unnecessarily with critical healthcare services.

Privacy: Encryption and access control reduce unauthorized exposure of patient information.

Availability: Redundancy, monitoring and recovery mechanisms help maintain healthcare services.

Cost: The architecture focuses on controls that provide meaningful risk reduction without unnecessary complexity.

Maintainability: Centralized logging and standardized security configurations simplify long-term administration.

18. ETHICAL AND PROFESSIONAL CONSIDERATIONS

All practical security testing is restricted to authorized laboratory systems. The project does not target real healthcare infrastructure or real patient information.

The assessment follows ethical-hacking principles by:

- Operating only within the approved scope
- Using non-destructive testing techniques

- Avoiding unauthorized access
- Protecting collected evidence
- Maintaining confidentiality
- Avoiding disruption of external systems

This approach is particularly important in healthcare because security testing must never create unnecessary risk to patient-related systems or services. The assignment explicitly requires an isolated authorized laboratory and responsible tool usage.

19. LIMITATIONS

The project is performed using a simulated healthcare environment and therefore does not completely reproduce the complexity of a production hospital network.

The CICIoMT2024 dataset provides representative attack traffic, but real-world attack behaviour can vary according to device configuration, network architecture and attacker techniques.

Automated tools may also produce informational or false-positive findings. Therefore, important findings should be manually reviewed before being classified as vulnerabilities.

Another limitation is that some IoMT and BLE devices may not provide the same level of logging or security configuration available in conventional IT systems.

20. FUTURE ENHANCEMENTS

The proposed environment can be improved through:

1. Machine-learning-based IoMT attack detection.
2. Continuous network monitoring.
3. Zero-trust access architecture.
4. Automated incident-response mechanisms.
5. Device identity management.

6. Continuous vulnerability assessment.
7. Behaviour-based anomaly detection.
8. Security automation for IoMT environments.

A machine-learning system trained using CICIoMT2024 features could provide an additional detection layer for identifying abnormal IoMT traffic.

21. CONCLUSION

This project examined the cybersecurity requirements of a smart healthcare environment using the CICIoMT2024 dataset and controlled ethical-hacking techniques.

The assessment considered multiple layers of the healthcare infrastructure, including IoMT devices, network services, Windows and Linux systems, web applications, Wi-Fi, MQTT, BLE and network traffic. The combination of dataset analysis and laboratory assessment provides a broader understanding of the threats that can affect interconnected healthcare environments.

The proposed secure architecture applies defense-in-depth through segmentation, firewall controls, authentication, authorization, encryption, intrusion detection, centralized logging, system hardening, patch management and recovery mechanisms.

The validation process provides measurable evidence of the security improvement achieved after implementing the proposed controls. More importantly, the project demonstrates that healthcare cybersecurity must balance technical protection with patient safety, privacy, availability and service continuity.

The resulting architecture therefore provides a practical foundation for reducing the attack surface of a smart healthcare environment while maintaining the operational requirements of connected healthcare services.

REFERENCES

1. Canadian Institute for Cybersecurity, **CICIoMT2024 – Attack Vectors in Healthcare Devices: A Multi-Protocol Dataset for Assessing IoMT Device Security**, University of New Brunswick.
2. Nmap Project, **Nmap Reference Guide**, Nmap Network Scanning Documentation.
3. OWASP Foundation, **OWASP ZAP Documentation**, Web Application Security Testing.
4. Wireshark Foundation, **Wireshark User's Guide**, Network Protocol Analysis Documentation.
5. OWASP Foundation, **OWASP Web Security Testing Guide**, Web Application Security Testing Methodology.
6. National Institute of Standards and Technology (NIST), **Cybersecurity Framework**, National Institute of Standards and Technology.

APPENDIX A – IMPORTANT COMMANDS

Host Discovery

```
nmap -sn <NETWORK>/24
```

Service Detection

```
nmap -sS -sV <TARGET-IP>
```

OS Detection

```
nmap -O <TARGET-IP>
```

Windows Enumeration

```
whoami
```

```
ipconfig /all
```

```
net user
```

```
net share
```

net session

sc query

Linux Enumeration

whoami

id

ip addr

ss -tulpen

systemctl --type=service --state=running

ls -la

Wireshark Filters

icmp

arp

mqtt

tcp.flags.syn == 1

tcp.flags.syn == 1 && tcp.flags.ack == 0

APPENDIX B – EVIDENCE RECORD

The practical evidence collected during the experiment includes:

- Kali Linux laboratory setup
- CICIoMT2024 dataset analysis
- Nmap host-discovery results
- Nmap port/service results
- Windows enumeration
- Linux enumeration

- Web application assessment
- Wi-Fi assessment
- MQTT assessment
- BLE assessment
- Wireshark traffic analysis
- Vulnerability register
- Proposed secure architecture
- Before-and-after validation